

GUÍA METODOLÓGICA DETALLADA

Kit de Encuesta DREAD — Métricas y Indicadores de Ciberseguridad 2025–2026

Fundamentos Epistemológicos, Diseño Muestral, Protocolo de Aplicación y Análisis

"Un instrumento de medición sin metodología es como un bisturí sin diagnóstico: puede hacer daño sin querer."

1. FUNDAMENTOS EPISTEMOLÓGICOS Y MARCO TEÓRICO

1.1 Naturaleza de la investigación

Esta encuesta se inscribe en el paradigma de la **investigación empírica mixta** (cuantitativa + cualitativa) aplicada a la gestión del riesgo de ciberseguridad. El marco DREAD —Damage, Reproducibility, Exploitability, Affected Users, Discoverability— proporciona el eje conceptual en torno al cual se articulan los ítems de medición.

La epistemología subyacente adopta una posición **post-positivista moderada**: reconoce la existencia de una realidad objetiva en el espacio de amenazas (vulnerabilidades, exploits, incidentes), al tiempo que acepta que la percepción, medición y respuesta a esa realidad está mediada por factores organizativos, culturales y de capacidad que solo pueden capturarse a través del juicio experto y la experiencia institucional.

1.2 Objetivos de la investigación

Objetivo	Tipo	Bloques relacionados
OB1: Medir la adopción real del marco DREAD en organizaciones españolas	Descriptivo	Bloque 1
OB2: Evaluar la madurez en la medición cuantitativa de cada dimensión DREAD	Diagnóstico	Bloques 2–6
OB3: Identificar la correlación entre madurez DREAD y capacidad de respuesta a incidentes	Correlacional	Bloques 7, 9
OB4: Comparar el uso de DREAD frente a frameworks alternativos	Comparativo	Bloque 8
OB5: Proyectar tendencias en la adopción de métricas avanzadas (ML, AHP, Fuzzy)	Prospectivo	Bloque 11
OB6: Contrastar el nivel de alineación normativa (NIS2, ENS, DORA) con la práctica real	Normativo	Bloques 8, 9
OB7: Capturar barreras y facilitadores de la evaluación cuantitativa de riesgos	Cualitativo	Bloque 12

1.3 Hipótesis de investigación

H1: La adopción formal del marco DREAD en organizaciones españolas es significativamente menor al 30% entre entidades no sujetas a ENS/NIS2, y mayor al 50% entre operadores esenciales/importantes.

H2: La dimensión "Usuarios Afectados" es la más subevaluada de las cinco, especialmente en organizaciones PYMEs y no-esenciales.

H3: Existe una correlación positiva y estadísticamente significativa entre el nivel de automatización del scoring de riesgos y el tiempo medio de detección/respuesta (MTTD/MTTR).

H4: La percepción de la "Descubribilidad" como dimensión problemática (por fomentar security-by-obscurity) está asociada inversamente al nivel de madurez en threat intelligence activa.

H5: Las organizaciones del sector financiero (sujetas a DORA) muestran mayor madurez en la cuantificación del Daño que las de otros sectores.

2. DISEÑO MUESTRAL Y ESTRATEGIA DE CAPTACIÓN

2.1 Universo y población objetivo

Universo principal: Responsables de ciberseguridad, tecnología y riesgo de organizaciones con sede o operaciones en España, con más de 10 empleados, en todos los sectores.

Estratificación propuesta:

Estrato	Criterio	Cuota mínima recomendada
E1 — Sector público	Administración central + autonómica + local	n = 80
E2 — Sector financiero	Bancos, aseguradoras, fintech (DORA)	n = 60
E3 — Energía e infraestructuras críticas	Eléctricas, agua, gas, telecomunicaciones	n = 50
E4 — Salud	Hospitales, laboratorios, farmacéuticas	n = 50
E5 — Gran empresa no crítica	+250 empleados, sectores no críticos	n = 80
E6 — PYME	10-249 empleados	n = 100
E7 — Educación e investigación	Universidades, centros I+D	n = 30
Total		n ≥ 450

2.2 Tamaño muestral y nivel de confianza

Para una población estimada de ~15.000 organizaciones en España con programa formal de ciberseguridad:

- Margen de error: $\pm 4.5\%$
- Nivel de confianza: 95%
- Proporción esperada: 50% (máxima variabilidad, escenario conservador)
- Tamaño muestral calculado: $n = 473$ (con ajuste por estratificación y efecto diseño = 1.2 $\rightarrow$ n ajustado ≥ 450)

2.3 Criterios de inclusión / exclusión

Criterios de inclusión:

- Organización con sede o actividad principal en España
- Encuestado con responsabilidad directa o indirecta en ciberseguridad, TI o gestión de riesgos
- Organización con al menos 10 empleados y alguna infraestructura digital relevante

Criterios de exclusión:

- Respuestas de personas físicas sin vínculo organizativo claro
- Cuestionarios con más del 30% de preguntas sin responder (bloque central)
- Organizaciones con sede fuera de la UE sin operaciones relevantes en España

2.4 Estrategia de captación

Canal primario: Distribución digital mediante enlace único anonimizado

- INCIBE (difusión entre su base de empresas registradas)
- CCN-CERT (difusión entre entidades del sector público)
- ISACA Spain Chapter, (ISC)² España, ISMS Forum Spain
- LinkedIn (campanas segmentadas a CISOs, CIOs, DPOs en España)

Canal secundario: Distribución presencial en eventos del sector

- CiberSeguridad Spain, RootedCON, NavajaNegra, ENISE
- Foros CISO sectoriales (FinCERT, SalCERT, EnergyCERT)

Canal terciario: Entrevistas semi-estructuradas (n = 20–30)

- Para profundidad cualitativa en organizaciones clave (operadores críticos, AAPP de nivel central)
- Guion basado en los bloques 12 (preguntas abiertas) y los bloques 7–9

3. PROTOCOLO DE ADMINISTRACIÓN

3.1 Versiones del instrumento

Versión	Bloques	Tiempo estimado	Público objetivo
Completa (v1.0)	0–12 (todos)	60–75 min	CISOs, responsables seguridad senior
Abreviada (v1.1) ★	0, 1★, 2★, 3★, 4★, 5★, 6★, 7★, 8★, 9★, 10★, 11★	20–30 min	CIOs, directivos no técnicos, PYMEs
Sectorial financiero (v1.2)	0, 1, 2, 4, 5, 7, 8 (P8.4 ampliado), 11	45 min	Entidades sujetas a DORA
Sectorial OT/ICS (v1.3)	0, 1, 2, 3, 4, 5, 6, 7, 9 (ampliado)	50 min	Operadores de infraestructuras críticas

3.2 Instrucciones para el administrador

1. Antes del envío: Personalizar el enlace de distribución con un identificador de estrato (E1–E7) para facilitar el análisis estratificado.
2. Durante el período de campo: Enviar un recordatorio a los 7 días del envío inicial. Si la tasa de respuesta es < 40%, enviar segundo recordatorio a los 14 días.
3. Período de campo recomendado: 4–6 semanas (considerar que agosto y primera quincena de septiembre tienen tasas de respuesta reducidas en España).
4. Control de calidad: Revisar semanalmente la distribución de respuestas por estrato; activar canales alternativos si algún estrato está infrarrepresentado.
5. Anonimización: Separar los datos de contacto de las respuestas inmediatamente al cerrar el formulario; solo conservar el identificador de estrato y el timestamp.

3.3 Gestión del sesgo de deseabilidad social

Las preguntas de esta encuesta abordan deficiencias organizativas. El sesgo de deseabilidad social —tendencia a responder lo que "debería ser" en lugar de lo que "es"— es el principal riesgo de validez interna.

Medidas de mitigación:

- Recordatorio explícito de confidencialidad al inicio y en cada bloque crítico.
- Preguntas formuladas como descriptivas ("¿Cómo evalúa actualmente...?"), no normativas ("¿Debería evaluar...?").
- Inclusión de opciones de respuesta que normalizan la ausencia de prácticas ("No evaluamos... / No tenemos...").
- Preguntas de consistencia cruzada (ej.: P0.4 vs. P7.1 vs. P10.3) para detectar respuestas inconsistentes.
- Versión de entrevista semi-estructurada para contraste cualitativo con muestra subconjunto.

4. SISTEMA DE CODIFICACIÓN Y ESCALAS

4.1 Escalas y codificación numérica

Escala de madurez (ítems tipo Likert ordinal 1–5):

- Nivel 1 = Inexistente → Puntuación numérica: 1
- Nivel 2 = Inicial/Ad hoc → Puntuación: 2
- Nivel 3 = Definido → Puntuación: 3
- Nivel 4 = Gestionado → Puntuación: 4
- Nivel 5 = Optimizado → Puntuación: 5

Ítems de selección múltiple (P1.2, P2.2, P4.4, P4.5, P5.3, P7.2, P11.2):

- Codificación binaria: cada opción = variable dicotómica (0 = no marcada, 1 = marcada)
- Suma de opciones marcadas → indicador de amplitud o exhaustividad de la práctica

Ítems de texto libre (Bloque 12):

- Análisis de contenido temático con codificación inductiva
- Software recomendado: NVivo, ATLAS.ti, o análisis manual con plantilla de categorías

4.2 Cálculo del Índice Global de Madurez DREAD (IGM-DREAD)

El IGM-DREAD es el indicador sintético que resume la madurez organizativa en la aplicación del marco DREAD. Se calcula como la media ponderada de los scores de madurez por dimensión:

$$\text{IGM-DREAD} = \sum (w_i \times \text{Score}_i) / \sum w_i$$

Donde:

- Score_D = Promedio de respuestas Bloque 2 (P2.1 a P2.5) → Peso $w_D = 0.25$
- Score_R = Promedio de respuestas Bloque 3 (P3.1 a P3.5) → Peso $w_R = 0.15$
- Score_E = Promedio de respuestas Bloque 4 (P4.1 a P4.5) → Peso $w_E = 0.20$
- Score_A = Promedio de respuestas Bloque 5 (P5.1 a P5.5) → Peso $w_A = 0.25$
- Score_Disc = Promedio de respuestas Bloque 6 (P6.1 a P6.4) → Peso $w_{\text{Disc}} = 0.15$

Pesos justificados por:

- Mayor peso en D y A: reflejan el impacto en negocio y la escala ciudadana, dimensiones más relevantes para gobernanza nacional
- Mayor peso en E: refleja la democratización del ataque por IA (2025)
- Menor peso en R y Disc: por su tratamiento como constantes (R=10, Disc=10) en muchas organizaciones maduras

Interpretación del IGM-DREAD:

Rango IGM-DREAD	Nivel de madurez	Recomendación principal
1.0 - 1.9	Inexistente	Iniciar programa básico de threat modeling con formación DREAD/CVSS
2.0 - 2.9	Inicial	Formalizar scoring con plantillas; habilitar feeds CVE/INCIBE-CERT
3.0 - 3.9	En desarrollo	Integrar DREAD con CVSS+EPSS; establecer KPIs de seguimiento
4.0 - 4.9	Gestionado	Automatizar scoring; integrar con SIEM/SOAR; reportar al Consejo
5.0	Optimizado	Evolucionar a DREAD ponderado AHP / Fuzzy DREAD / ML-enhanced DREAD

5. ANÁLISIS ESTADÍSTICO

5.1 Análisis descriptivo

Para cada ítem y bloque:

- Frecuencias absolutas y relativas por categoría de respuesta
- Media y desviación estándar para ítems ordinales (con precaución epistemológica sobre la naturaleza ordinal)
- Mediana y percentiles 25/75 para distribuciones asimétricas
- Segmentación por variables de clasificación: sector (P0.1), tamaño (P0.2), rol (P0.3), NIS2 (P0.5)

5.2 Análisis inferencial

- Test de Kruskal-Wallis para comparar IGM-DREAD entre sectores (datos ordinales, más de 2 grupos)
- Test de Mann-Whitney U para comparar pares de sectores / tamaños
- Análisis de correlación de Spearman entre IGM-DREAD y:
- MTTR de vulnerabilidades críticas (P3.4)
- Presupuesto de ciberseguridad (P10.3)
- Nivel de automatización (P7.1)
- Regresión logística ordinal para modelar probabilidad de alcanzar nivel de madurez IGM ≥ 4 en función de: sector, tamaño, presupuesto, uso de frameworks, alineación NIS2

5.3 Análisis de componentes principales (ACP)

Para identificar la estructura latente del espacio de madurez en ciberseguridad: ¿existen dimensiones subyacentes que agrupen ciertos comportamientos organizativos? El ACP sobre los 50+ ítems ordinales (con matrices policóricas) revelará si los cinco indicadores DREAD se comportan como dimensiones realmente independientes o si hay factores organizativos transversales.

5.4 Análisis cualitativo (Bloque 12)

- Codificación temática inductiva de respuestas abiertas
- Identificación de patrones recurrentes en las tres preguntas cualitativas
- Triangulación con datos cuantitativos: ¿coinciden las barreras declaradas (P12.2) con las medidas de capacidad observadas (P7.1, P10.3)?

6. VALIDACIÓN DEL INSTRUMENTO

6.1 Validez de contenido

Proceso de revisión por panel de expertos (n = 8–10) antes del despliegue:

- 2 investigadores académicos en ciberseguridad (universidades españolas)
- 2 CISOs de organizaciones con alta madurez (operadores esenciales)
- 1 representante de INCIBE / CCN-CERT
- 1 auditor certificado (CISA / ISO 27001 Lead Auditor)
- 1 jurista especialista en NIS2 / GDPR
- 1 experto en diseño de encuestas y metodología de investigación

Criterios de evaluación por ítem: relevancia, claridad, exhaustividad de opciones, ausencia de sesgo en el redactado.

6.2 Validez aparente (Face Validity)

Prueba piloto con muestra pequeña (n = 20–25):

- 5 CISOs de PYMEs
- 5 CISOs de grandes organizaciones
- 5 responsables de riesgo / compliance
- 5 técnicos de seguridad

Métricas de validez aparente: tiempo de cumplimentación real vs. estimado, preguntas consideradas ambiguas, opciones de respuesta consideradas incompletas.

6.3 Fiabilidad (consistencia interna)

- Alpha de Cronbach para cada bloque temático (ítems con escala ordinal comparable)
- Umbral mínimo aceptable: $\alpha \geq 0.70$
- Para ítems de selección múltiple: correlación inter-ítem promedio ≥ 0.30

6.4 Validez de constructo

- Análisis Factorial Confirmatorio (AFC) para verificar que los cinco bloques DREAD (2–6) se corresponden con cinco factores diferenciados en el espacio de varianza
- Índices de ajuste objetivo: CFI ≥ 0.90 , RMSEA ≤ 0.08

7. CONSIDERACIONES ÉTICAS Y LEGALES

7.1 Marco normativo aplicable

- RGPD (Reglamento UE 2016/679): Los datos de los encuestados son datos personales (nombre, rol, organización). Se aplican principios de minimización, finalidad, exactitud y limitación del plazo de conservación.
- LOPDGDD (Ley Orgánica 3/2018): Legislación española de aplicación directa.
- Código Deontológico de ESOMAR / ICC: Para investigaciones de mercado y sociales con encuestas.

7.2 Medidas de protección de datos

- No se recogerá el nombre de la organización si el encuestado elige responder de forma anónima total.
- Los datos identificativos se separan de las respuestas en el momento de la recepción.
- Los datos se almacenan en servidores dentro de la UE con cifrado en reposo y en tránsito.
- El período de conservación de datos identificativos es de 24 meses; los datos anonimizados se pueden conservar indefinidamente para fines de investigación.
- Los encuestados tienen derecho de acceso, rectificación, supresión y portabilidad (artículos 15–20 RGPD).

7.3 Declaración de conflicto de intereses

Los investigadores que administren esta encuesta deben declarar explícitamente cualquier relación comercial o financiera con proveedores de herramientas de ciberseguridad, consultoras o certificadoras que pudiera influir en el diseño, análisis o comunicación de resultados.

8. PLAN DE DIFUSIÓN DE RESULTADOS

8.1 Productos de conocimiento previstos

Producto	Formato	Audiencia	Canal de difusión
Informe ejecutivo (5-8 páginas)	PDF	CISOs, directivos	INCIBE, CCN-CERT, LinkedIn
Informe completo de investigación	PDF / Web	Investigadores, reguladores	DOI / repositorio académico
Dashboard interactivo	Web	Sector	INCIBE / ISMS Forum
Artículo académico (peer-reviewed)	Revista indexada	Comunidad científica	ESWA, Computers & Security, MDPI
Nota de política (policy brief)	PDF 2 páginas	CNCS, Ministerio de Transformación Digital	Canal institucional
Presentación sectorial (x5)	Slides	Cada sector	Eventos ISAC, RootedCON, etc.

8.2 Calendario indicativo

Fase	Actividad	Duración
M1	Validación del instrumento (panel expertos)	3 semanas
M2	Piloto y ajuste	2 semanas
M3-M4	Trabajo de campo (distribución + recogida)	6 semanas
M5	Limpieza de datos y codificación	2 semanas
M6	Análisis estadístico	3 semanas
M7	Redacción del informe	3 semanas
M8	Revisión y difusión	2 semanas

Kit de Encuesta DREAD · Guía Metodológica v1.0 · Abril 2026

Diseñada con base en: metodología GQM (INCIBE-IMC), FAIR, ENISA CTL Methodology 2025, NIS2, ENS, DORA